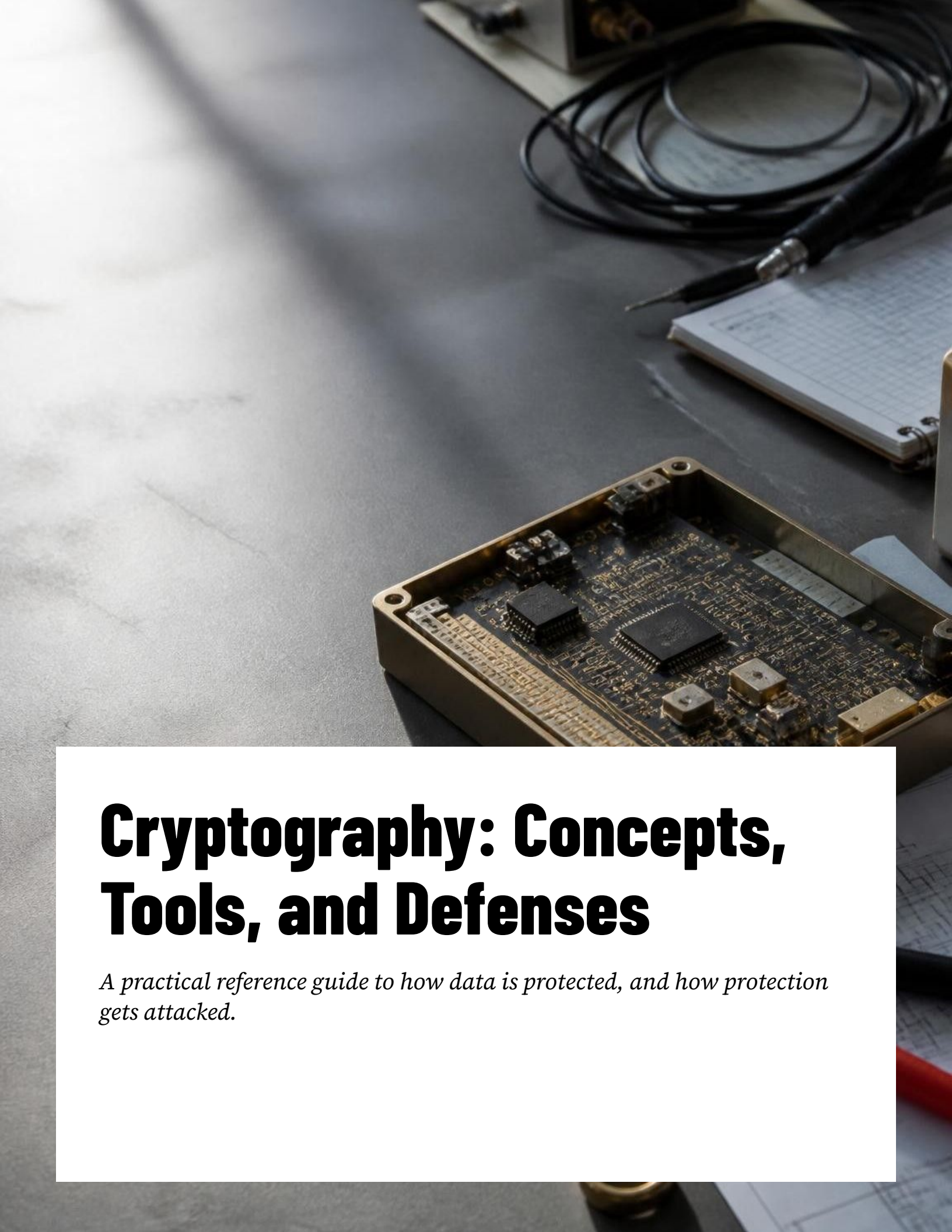


Cryptography: Concepts, Tools, and Defenses

A practical reference guide to how data is protected, and how protection gets attacked.

FOUNDATIONS

Cryptography Concepts

CONCEPT	ROLE IN CRYPTOGRAPHY
Security goals	Confidentiality, integrity, authentication, and non-repudiation.
Core elements	Plaintext is transformed into ciphertext by algorithms using keys.
Methods	Symmetric vs. asymmetric encryption, hashing, and digital signatures.

Kerckhoffs's Principle

Security rests on the key, not secrecy of the algorithm.



A mechanical cipher dial beside modern cryptographic silicon.

PRIMITIVES & CIPHERS

Encryption Algorithms

Technical specifications, mathematical foundations, and security baselines.

Symmetric: AES, DES and 3DES, Blowfish, ChaCha20. Asymmetric: RSA, Diffie-Hellman, elliptic curve cryptography. Hash functions: SHA-2, SHA-3, and why MD5 and SHA-1 are retired. Block vs. stream ciphers and modes of operation.

Symmetric & RSA

AES

Symmetric (Block); 128, 192, 256 b. Current global standard. Requires authenticated modes like GCM; CBC requires explicit MAC.

ChaCha20

Symmetric (Stream); 256 b. Paired with Poly1305 authenticator. Exceptional constant-time performance on platforms lacking AES-NI.

RSA

Asymmetric (Factor); 2048–4096 b. Legacy standard for encryption and signing. Keys below 2048 bits are vulnerable to factorization.

Block Cipher Modes of Operation

Never use Electronic Codebook (ECB) as it preserves underlying plaintext patterns. Authenticated modes such as GCM (Galois/Counter Mode) provide simultaneous confidentiality and integrity checks.

Curves & Hashes

ECDSA / Ed25519

Asymmetric (Curves); 256–384 b. High performance with small footprint; 256-bit ECC matches the security margin of 3072-bit RSA.

SHA-2 / SHA-3

Cryptographic Hash; 256, 384, 512 b. Current collision-resistant standard. SHA-3 sponge construction provides algorithmic defense-in-depth.

MD5 & SHA-1

Cryptographic Hash; 128, 160 b. **Deprecated & Insecure.** Practical collision attacks exist (SHAttered); prohibited in compliance baselines.

Stream Ciphers & Nonce Discipline

Stream ciphers encrypt plaintext bit-by-bit via a pseudorandom keystream. Reusing a nonce with the same key destroys confidentiality completely, exposing plaintexts to trivial XOR recovery.

IMPLEMENTATION TOOLKIT

Cryptography Tools

Operational utilities and hardware environments for production environments.

CLI / TLS ENGINE

OpenSSL

The primary command-line Swiss army knife for generating RSA/EC private keys, crafting Certificate Signing Requests (CSRs), inspecting ASN.1 certificate structures, and testing live TLS handshakes and ciphersuites across endpoints.

OPENPGP STANDARD

GnuPG (GPG)

GnuPG for file and email encryption and signing. Complete RFC 4880 and RFC 9580 implementation used for signing Git commits, verifying package repository integrity, encrypting documents at rest, and managing personal cryptographic keyrings across distributed systems.

INTEGRITY CHECKING

Checksums & Hashes

Utilities including `sha256sum`, `b2sum`, and `openssl dgst` calculate cryptographic digests to verify software download integrity, detect unintended file corruption, and automate artifact verification pipelines.

SECRET MANAGEMENT

Password Vaults

Password managers: Enterprise managers leverage memory-hard key derivation functions like Argon2id and PBKDF2 to derive encryption keys from master passwords, protecting credentials at rest using client-side authenticated AES-256-GCM.

HARDWARE ROOT

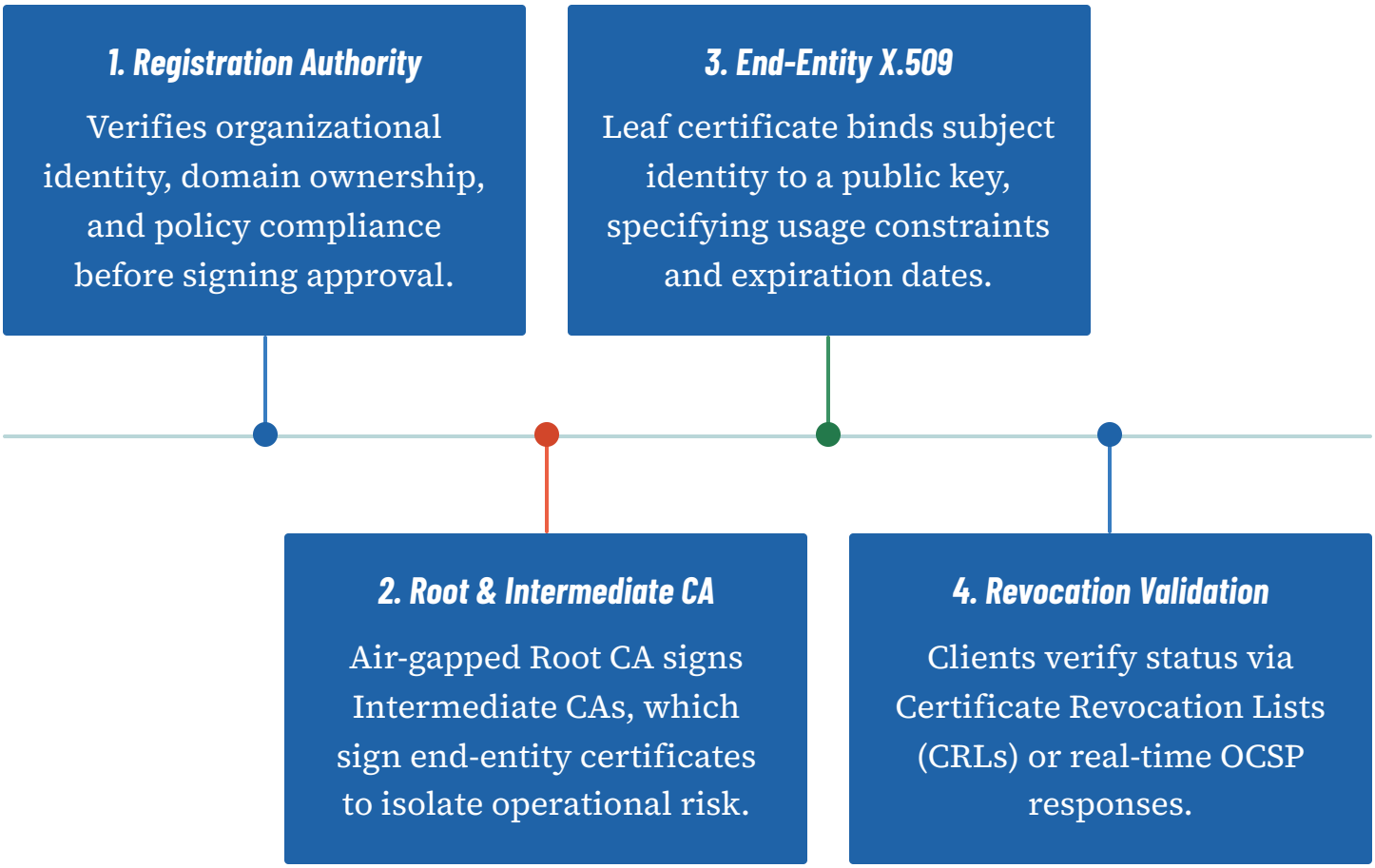
HSM & Cloud KMS

Hardware Security Modules (FIPS 140-2/3 Level 3+) and cloud KMS solutions isolate cryptographic keys within tamper-resistant silicon, ensuring that private keys never enter host memory during sign or decrypt operations.

TRUST ARCHITECTURE

Public Key Infrastructure (PKI)

Binding cryptographic identities to verified public keys across global networks.



The X.509 Chain of Trust

Repositories publish certificates; client applications store a trusted set of Root CA certificates in a local trust store. Certificates are issued and renewed through the PKI. During TLS handshakes, servers present leaf and intermediate certificates; clients verify cryptographic signatures hierarchically up to a trusted Root CA.

Operational Underpinnings

PKI provides mutual authentication and confidentiality for HTTPS web traffic, validates executable publisher signatures to defeat malware injection, establishes IPSec and WireGuard corporate VPN tunnels, and secures internal service meshes via mTLS.

MESSAGING SECURITY

Email Encryption

End-to-end payload defense, operational trust models, and protocol trade-offs.

S/MIME (Enterprise PKI)

Built directly into enterprise email clients. Relies on centralized X.509 certificates issued by public or corporate Certificate Authorities. Simplifies automated enterprise deployment but requires rigorous centralized certificate management.

PGP / OpenPGP (Web of Trust)

Decentralized model where users sign each other's public keys without relying on a central authority. Highly flexible for individual practitioners and developers, though key discovery and trust verification demand technical diligence.

Transport vs. Rest Security

STARTTLS encrypts the connection between mail transfer agents (MTAs) in transit. It does not protect the message at rest on intermediary mail servers. True privacy requires client-side asymmetric payload encryption.

The Metadata Problem

S/MIME and PGP encrypt only the message body and attachments. Critical routing headers (Subject, Sender, Recipient, Timestamp, Server IP) remain exposed in cleartext across every transit hop.

Key Exchange Constraint: Secure communication requires possessing the recipient's verified public key before sending. Public keyservers and automated protocols (such as Autocrypt and WKD) attempt to resolve this discovery bottleneck.

DATA AT REST

Disk Encryption

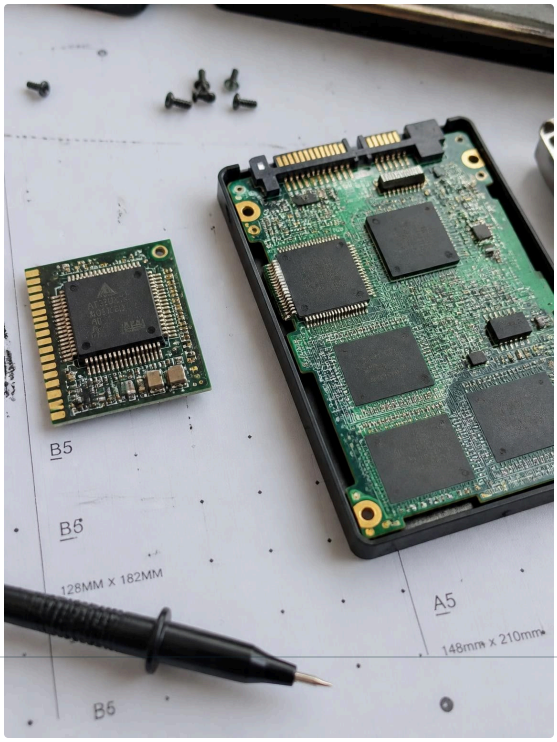
Protecting storage media against physical extraction, theft, and offline attacks.

Full-disk vs. file-level encryption protects lost or stolen devices, not a running, unlocked system. Consider recovery keys, TPM use, and pre-boot authentication.

SOLUTION	PLATFORM & STANDARD	PRIMARY ARCHITECTURE
BitLocker	Microsoft Windows	XTS-AES-128/256 tied to TPM; verifies bootloader integrity via PCR measurements.
FileVault 2	Apple macOS	XTS-AES-128; hardware encryption engine integrated into Apple Secure Enclave.
dm-crypt / LUKS	Linux Environments	Modular kernel block encryption supports multiple keyslots and Argon2 key derivation.
VeraCrypt	Cross-Platform Open Source	File-hosted containers or system partitions; supports cascaded ciphers and hidden volumes.

The Operational Threat Model

Disk encryption protects data on devices powered down or unmounted. Once the operating system boots, authenticates, and decrypts the master volume key into RAM, active memory attacks, local malware, and authenticated physical sessions bypass full-disk protection entirely.



Cryptanalysis

Brute Force & Dictionary

Exhaustive searches of key spaces or credential dictionaries. Work factor scales exponentially with key length (2^n). Mitigate with large cryptographic keys and salted memory-hard derivation functions.

Known- & Chosen-Plaintext (CPA)

Known-plaintext attacks use known plaintext-ciphertext pairs. In chosen-plaintext attacks, adversaries select inputs and observe ciphertexts. IND-CPA security uses unique initialization vectors so identical plaintexts encrypt to distinct ciphertexts.

Chosen-Ciphertext (CCA)

Attackers submit crafted ciphertexts to a decryption oracle and analyze outputs. Unauthenticated encryption modes risk padding oracle attacks; authenticated encryption (AEAD) addresses this.

Linear, Differential & Side-Channel

Linear and differential cryptanalysis analyze linear approximations and input differences through cipher substitution-permutation networks to extract subkey bits faster than exhaustive search. Side-channel attacks exploit physical, not mathematical, flaws: timing, power consumption analysis (DPA), and electromagnetic radiation during execution. Constant-time coding prevents these leaks.

Birthday Attacks

The birthday paradox enables hash collisions in $2^{n/2}$ operations rather than 2^n. A minimum 256-bit hash length provides a 128-bit security margin.

Man-in-the-Middle (MitM) Interception

Attackers intercept key exchanges without mutual authentication. Defenses: authoritative digital certificates, strict pinning, and authenticated ephemeral Diffie-Hellman protocols.

DEFENSIVE ARCHITECTURE

Countermeasures

Engineering rules for building and maintaining robust cryptographic systems.

RULE 01 *Vetted Algorithms*	Never design custom ciphers. Mandate industry-standard primitives: AES-256-GCM, ChaCha20-Poly1305, Ed25519, and SHA-384. Deprecate legacy algorithms (DES, 3DES, RC4, MD5, SHA-1) across all infrastructure.
RULE 02 *Entropy & Rotation*	Generate keys using cryptographically secure pseudorandom number generators (CSPRNGs) sourced from hardware noise pools. Enforce automated key rotation schedules to minimize the data volume protected by a single key.
RULE 03 *Hardware Isolation*	Store master encryption keys in dedicated Hardware Security Modules (HSMs) or enterprise KMS vaults. Never store encryption keys in plaintext config files, repositories, or memory shared with target payload databases.
RULE 04 *Strict Validation*	Implement complete certificate chain validation, enforcing strict expiration checks, revocation status verification (OCSP stapling), and hostname matching. Patch underlying crypto libraries immediately upon CVE disclosure.
MANDATE 05 *Post-Quantum Prep*	Audit systems for quantum vulnerability. Plan migration from classical factoring/discrete-log algorithms (RSA, ECC) toward NIST Post-Quantum Cryptography standards: ML-KEM (Kyber) and ML-DSA (Dilithium).